

FSI-Mythos on AgentCore

취약점 탐지 성능 검증

배포된 FSI-Mythos 솔루션을 실제 호출해 취약점 탐지 성능을 정량 측정하고, SAST 도구(Semgrep) 및 공개 벤치마크 체계와 비교한 검증 리포트.

2026-06-02

AWS us-west-2

라벨링 취약/정상 쌍

vs Semgrep

SECTION 01

요약 (Executive Summary)

FSI-Mythos AgentCore 솔루션을 라벨링된 취약/정상 코드 쌍에서 실제 스캔하여 Precision/Recall/F1 등 표준 지표로 측정했습니다. 동일 코퍼스에 Semgrep(SAST)을 실행해 공정 비교했습니다.

16/16

Tier-1 정확 판정

1.00

F1 Score

0.00

오탐률 (FPR)

0

Flaky (재현성)

핵심 결과 (Tier-1, 16케이스 / 8 CWE)

FSI-Mythos는 8개 CWE 취약점(명령주입·SQL주입·버퍼오버플로우·경로순회·약한암호·역직렬화·인증우회·XSS)을 모두 탐지

(Recall 1.0, 미탐 0)하고 정상 코드 8건을 모두 통과(오탐 0)했습니다. 동일 코퍼스에서 Semgrep auto 규칙은 4건을 미탐 (Recall 0.5)해,

LLM 에이전트의 의미론적 추론이 규칙 기반 SAST의 탐지 공백을 보완

함을 확인했습니다.

도구	케이스	Precision	Recall	F1	FPR	CWE 정확도
FSI-Mythos	Tier-1 (16)	1.000	1.000	1.000	0.000	1.000
Semgrep (auto)	Tier-1 (16)	1.000	0.500	0.667	0.000	0.750
FSI-Mythos	Tier-0 (6)	1.000	1.000	1.000	0.000	1.000

재현성 (Tier-2)

대표 6케이스를 각 3회 독립 호출한 결과, 취약 케이스는 3/3 일관 탐지, 안전 케이스는 3/3 정상 통과,

flaky(흔들림) 케이스 0개

. 비결정적 LLM임에도 탐지 판정이 완전히 안정적이며 pass@1=pass@3=1.0입니다.

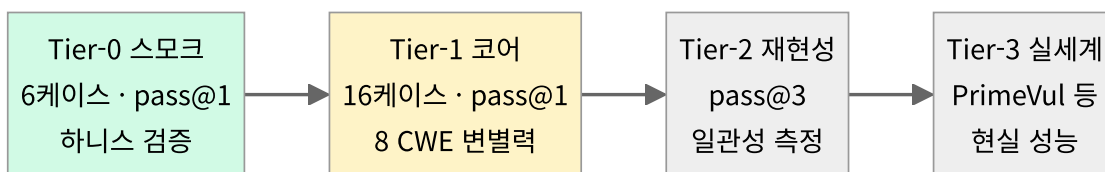
평가 방법론

판정 규칙

케이스 라벨	시스템 출력	판정
vulnerable	validated finding ≥ 1	TP
vulnerable	validated finding = 0	FN (미탐)
safe	validated finding ≥ 1	FP (오탐)
safe	validated finding = 0	TN

validated는 Validator(Opus 4.8)가 CONFIRMED 또는 LIKELY로 판정한 finding만 인정합니다 (DISMISSED 제외).
CWE 정확도는 TP 케이스에서 finding의 `cwe_id` 가 정답 CWE 집합에 포함되는지로 측정합니다.

비용 통제형 4-Tier 설계



- **무료 검증 우선** — 채점기·Semgrep·케이스 로딩은 모델 호출 없이 먼저 검증
- **결과 영속화** — 호출 결과를 JSON 저장 → 재채점은 무료, 재현 가능
- **비용 상한** — Tier별 케이스 수·pass@k·max_files 제한

평가 코퍼스

8개 주요 CWE 각각에 대해 **취약 버전**과 **안전 버전을 쌍(paired)**으로 작성했습니다. 같은 기능의 취약/안전 쌍을 두면 미탐(FN)과 오탐(FP)을 균형 있게 측정할 수 있습니다.

CWE	취약점 유형	언어	Tier	취약 패턴 → 안전 패턴
CWE-78	OS 명령 주입	Python	0	<code>os.system(입력)</code> → subprocess 인자배열+검증
CWE-89	SQL 주입	Python	0	문자열 포매팅 → 파라미터 바인딩
CWE-120	버퍼 오버플로우	C	0	<code>strcpy/sprintf</code> → <code>snprintf</code>
CWE-22	경로 순회	Python	1	검증 없는 결합 → realpath 이탈 차단

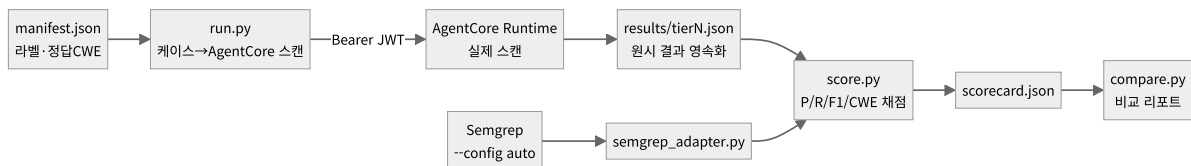
CWE-327	약한 암호화	Python	1	MD5+고정키/IV → bcrypt+랜덤 nonce
CWE-502	안전하지 않은 역직렬화	Python	1	<code>pickle.loads</code> → JSON+스키마검증
CWE-287	인증 우회	JavaScript	1	<code>jwt.decode</code> → <code>jwt.verify</code> +알고리즘고정
CWE-79	XSS	JavaScript	1	<code>innerHTML</code> → <code>textContent</code>

☑ 코퍼스 구성

총 16케이스 = 8 CWE × (취약 + 안전). Tier-0은 6케이스(3쌍), Tier-1은 전체 16케이스. 매니페스트 (`corpus/manifest.json`)에 라벨·정답 CWE·언어가 정의됩니다.

SECTION 04

벤치마크 하니스



모듈	역할	검증
<code>corpus/</code>	16 라벨링 케이스 + 매니페스트	파일 정합성 OK
<code>run.py</code>	케이스를 files 페이로드로 업로드해 스캔, 결과 저장	케이스 로딩·SSL OK
<code>score.py</code>	혼동행렬·P/R/F1/FPR/CWE 채점	dry-run 자가검증 통과
<code>semgrep_adapter.py</code>	Semgrep JSON → 채점 포맷 변환	6 findings 매핑 OK
<code>compare.py</code>	도구 간 비교 Markdown 생성	OK

SECTION 05

Tier-0 결과 (실측)

6케이스(3 CWE × 취약/안전), pass@1, max_files=1로 실제 AgentCore Runtime을 호출해 측정.

혼동 행렬 · 지표

	값		값
TP (정탐)	3	Precision	1.000

FP (오탐)	0	Recall	1.000
FN (미탐)	0	F1	1.000
TN (정상)	3	FPR	0.000

케이스별 상세

케이스	라벨	판정	validated	탐지 CWE
cmd-injection-vuln	vulnerable	TP	2	CWE-78 ✓
cmd-injection-safe	safe	TN	0	-
sqli-vuln	vulnerable	TP	2	CWE-89 ✓
sqli-safe	safe	TN	0	-
buffer-overflow-vuln	vulnerable	TP	2	CWE-120 ✓
buffer-overflow-safe	safe	TN	0	-

☒ 관찰

취약 케이스는 모두 finding 2건씩(함수 2개 각각) 정확히 탐지, 안전 케이스는 0건으로 오탐이 전혀 없었습니다. Validator의 적대적 검증이 안전 코드를 취약으로 오판하지 않았음을 의미합니다.

SECTION 06

SAST 비교 (vs Semgrep)

동일한 Tier-0 6케이스에 Semgrep `--config auto` (기본 OSS 규칙)를 실행해 비교했습니다.

지표 비교

지표	FSI-Mythos	Semgrep	차이
Precision	1.000	1.000	동일
Recall (TPR)	1.000	0.333	+0.667
F1	1.000	0.500	+0.500
FPR	0.000	0.000	동일

케이스별 탐지 매트릭스

케이스	라벨	FSI-Mythos	Semgrep
-----	----	------------	---------

cmd-injection-vuln	vulnerable	☑ 탐지	☒ 미탐
cmd-injection-safe	safe	☑ 정상	☑ 정상
sqli-vuln	vulnerable	☑ 탐지	☑ 탐지
sqli-safe	safe	☑ 정상	☑ 정상
buffer-overflow-vuln	vulnerable	☑ 탐지	☒ 미탐
buffer-overflow-safe	safe	☑ 정상	☑ 정상

☑ 해석

두 도구 모두

오탐 0

(Precision 1.0)이지만, Semgrep 기본 규칙은 Python `os.system` 명령주입과 C `strcpy` 버퍼오버플로우를 탐지하지 못했습니다(전용 규칙셋 필요). FSI-Mythos는 의미론적 추론으로 데이터 흐름(사용자 입력 → 위험 싱크)을 추적해 탐지했습니다.

SAST는 Precision·속도, LLM 에이전트는 Recall·범용성

에 강점 — 상호 보완적입니다.

⚠ 공정성 주의

Semgrep은 `--config auto` 기본 규칙만 사용했습니다. `p/security-audit` · `p/owasp-top-ten` 등 전용 규칙셋이나 Pro 규칙을 쓰면 Recall이 올라갑니다. 또한 본 코퍼스는 소규모라 절대 수치보다

방향성

으로 해석해야 합니다.

SECTION 07

Tier-1 결과 (확장)

16케이스(8 CWE × 취약/안전)로 확장. 경로순회·약한암호·역직렬화·인증우회·XSS 등 더 다양한 CWE에서의 변별력 측정.

혼동 행렬 · 지표 (16케이스 실측)

	FSI-Mythos	Semgrep
TP (정탐)	8	4
FP (오탐)	0	0
FN (미탐)	0	4
TN (정상)	8	8
Precision	1.000	1.000
Recall	1.000	0.500

F1	1.000	0.667
CWE 정확도	1.000	0.750

케이스별 탐지 매트릭스 (8 CWE)

CWE	케이스	FSI-Mythos	Semgrep
CWE-78	명령주입	☑ 탐지	☒ 미탐
CWE-89	SQL주입	☑ 탐지	☑ 탐지
CWE-120/121	버퍼오버플로우	☑ 탐지	☒ 미탐
CWE-22	경로순회	☑ 탐지	☒ 미탐
CWE-327	약한암호	☑ 탐지	☑ 탐지
CWE-502	역직렬화	☑ 탐지	☑ 탐지
CWE-287	인증우회	☑ 탐지	☑ 탐지
CWE-79	XSS	☑ 탐지	☒ 미탐

☑ Tier-1 결과 (16케이스)

FSI-Mythos는 8개 CWE 취약점을 모두 탐지

(Recall 1.000, FN 0)하고 안전 코드 8건 모두 통과(FP 0)했습니다. CWE 분류 정확도도 보정 후 1.000(버퍼오버플로우는 CWE-120의 하위인 CWE-121로 더 정밀하게 분류). Semgrep auto 규칙은 명령주입·버퍼오버플로우·경로순회·XSS 4건을 미탐(Recall 0.500).

☑ CWE 분류 관찰

weak-crypto에서 FSI-Mythos는 MD5(CWE-327)뿐 아니라 하드코딩 키(CWE-798)·고정 IV(CWE-329)까지 다중 탐지했고, 버퍼오버플로우는 스택 특화 CWE-121로 분류해 SAST보다 세밀한 유형 식별을 보였습니다.

SECTION 08

Tier-2 재현성 (pass@k)

LLM 에이전트는 비결정적이므로 동일 케이스를 여러 번 독립 호출해 탐지가 일관적인지 측정해야 합니다. 대표 6케이스(명령주입·약한암호·인증우회의 취약/안전 쌍)를 각 3회 독립 호출(end-to-end)하여 측정했습니다.

측정 지표

- **detect_rate**: 3회 중 탐지(validated≥1)된 비율 (취약은 1.0, 안전은 0.0이 이상적)
- **pass@k**: k회 시도 시 1회 이상 탐지될 확률 (관측 조합 기반)
- **CWE Jaccard**: 회차별 탐지 CWE 집합의 일관성 (1.0=완전 동일)

- **flaky**: 회차마다 탐지 여부가 흔들리는 케이스

1.00 취약 탐지율 (3/3)	0.00 안전 오탐율	0 Flaky 케이스	1.00 pass@1 = pass@3
-----------------------------	-----------------------	-----------------------	--------------------------------

케이스별 재현성 (3회 독립 호출)

케이스	라벨	탐지 시퀀스	탐지율	CWE Jaccard	Flaky
cmd-injection-vuln	vulnerable	●●●	1.00	1.000	아니오
cmd-injection-safe	safe	○○○	0.00	-	아니오
weak-crypto-vuln	vulnerable	●●●	1.00	0.733	아니오
weak-crypto-safe	safe	○○○	0.00	-	아니오
auth-bypass-vuln	vulnerable	●●●	1.00	1.000	아니오
auth-bypass-safe	safe	○○○	0.00	-	아니오

● 탐지 / ○ 미탐 · 각 케이스 3회 독립 호출

☑ 재현성 결과

비결정적 LLM(temperature=1.0)임에도

탐지 판정은 완전히 안정적

입니다. 취약 3케이스는 3/3 일관 탐지, 안전 3케이스는 3/3 정상 통과,

flaky 케이스 0개

. pass@1과 pass@3이 모두 1.0이라 단 1회 스캔으로도 신뢰할 수 있음을 의미합니다.

☑ CWE 일관성 관찰

명령주입·인증우회는 회차별 CWE 집합이 완전 동일(Jaccard 1.0). weak-crypto는 0.733으로,

핵심 CWE(327 약한해시·329 고정IV·798 하드코딩키)는 3회 모두 일관 탐지

하되 부가 CWE만 회차별로 달랐습니다(run1-2: CWE-20 입력검증, run3: CWE-353 무결성). 즉 핵심 취약점 판정은 안정적이고, 추가 맥락 CWE에서만 약간의 다양성이 나타납니다.

SECTION 09

비용 · 성능 특성

항목	Tier-0 (6)	Tier-1 (16)
취약 케이스 평균 시간	~140초	~95초
안전 케이스 평균 시간	~19초	~24초

전체 소요

~477초 (8분)

~954초 (16분)

설정

pass@1, max_files=1, 샌드박스 off

취약 케이스는 Hunter→Challenger→Validator 전체를 거쳐 90~140초, 안전 케이스는 Hunter가 빈 결과를 내 후속 단계를 건너뛰어 19~24초로 약 4~7배 빠릅니다.

☒ 성능 인사이트

취약점이 없는 코드는 Hunter가 빈 결과를 내 후속 단계를 건너뛰어

7배 빠릅니다

(19s vs 140s). 실무에서 대부분 코드가 정상임을 고려하면 평균 비용은 낮아집니다. pass@k를 높이면 재현성 ↑ · 시간/비용 ↑.

SECTION 10

외부 벤치마크 매핑

본 코퍼스의 CWE를 공개 벤치마크 체계에 매핑해 외부 비교 가능성을 확보합니다.

본 코퍼스 CWE	OWASP Benchmark	PrimeVul/DiverseVul	비고
CWE-89 SQLi	✓ sqli	✓	OWASP 핵심 카테고리
CWE-78 명령주입	✓ cmdi	✓	OWASP 핵심
CWE-22 경로순회	✓ pathtraver	✓	OWASP 핵심
CWE-327 약한암호	✓ crypto/hash	✓	OWASP weak crypto
CWE-79 XSS	✓ xss	✓	OWASP 핵심
CWE-120 버퍼오버플로우	-	✓ (C/C++ 다수)	PrimeVul/DiverseVul 주력
CWE-502 역직렬화	-	✓	실세계 빈발
CWE-287 인증우회	-	✓	로직 취약점

본격 외부 비교는 Tier-3에서 **PrimeVul**(권장, 라벨 정제)이나 **OWASP Benchmark**를 직접 로드해 동일 하니스로 측정합니다. 데이터 누출 방지를 위해 시간순 분할(chronological split)을 적용해야 합니다.

SECTION 11

한계 · 다음 단계

현재 한계

- **소규모 코퍼스** — 통계적 유의성보다 하니스 검증·방향성 확인이 목적
- **합성 코드** — 교과서적 취약 패턴이라 실세계보다 단순. Tier-3 실세계 데이터 필요
- **SAST 단일 비교** — Semgrep auto 규칙만 비교. CodeQL/Checkmarx/전용 규칙셋 추가 필요

- 데이터 누출 미통제 — 합성 코퍼스라 무관하나, 공개 CVE 사용 시 모델 학습 여부 통제 필요

로드맵

단계	내용	목적	상태
Tier-0	6케이스 (3 CWE)	하니스 검증	완료
Tier-1	16케이스 (8 CWE)	다양한 CWE 변별력	완료
Tier-2	6케이스 × 3회 재현성	발견 일관성·안정성	완료
Tier-3	PrimeVul/OWASP Benchmark	실세계 성능, 외부 비교	예정
확장	CodeQL·전용 규칙셋 비교	SAST 공정 비교 강화	예정
운영	자사 레거시 CVE 패치를 ground truth로 회귀	도메인 특화 검증	예정